

Security+ 1.4 · Key Exchange

Mestre CyberSec · Aula 1.4 — Key Exchange (3:39) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Diffie-Hellman: duas partes derivam a MESMA chave secreta trocando só valores PÚBLICOS — sem enviar a chave! Na TLS moderna usa-se ECDHE (efêmero): chave NOVA a cada sessão, dando Perfect Forward Secrecy (se a chave privada vazar amanhã, sessões passadas não decifram).

💡 Highlights que a prova CompTIA cobra

- DH troca valores públicos e deriva chave privada — a chave NUNCA viaja
- Ephemeral (ECDHE) = chave por sessão — PFS
- PFS = se a chave privada vazar, as sessões PASSADAS não são decifradas

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman
- 'protects past sessions even if key leaks' = Perfect Forward Secrecy

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Diffie-Hellman (DH)

Protocolo assimétrico de acordo de chaves que permite a duas partes derivarem o mesmo segredo compartilhado em um canal inseguro trocando apenas valores públicos — a chave secreta nunca é transmitida.

⚠ **Armadilha CompTIA:** Exam trigger 'derive a shared secret over an untrusted channel' = DH. Do NOT confuse with RSA: RSA ENCRYPTS/TRANSPORTS a key, DH AGREES/DERIVES a key.

• Sigilo Encaminhado Perfeito (PFS)

Propriedade criptográfica que garante que o comprometimento de uma chave privada de longo prazo NÃO compromete a confidencialidade de sessões passadas, pois cada sessão usou uma chave efêmera única.

⚠ **Armadilha CompTIA:** Exam trigger 'protects past sessions even if private key leaks' = PFS. Memorize: PFS requires ephemeral keys (DHE/ECDHE); static DH does NOT provide PFS.

• Chave Efêmera (N/A)

Chave criptográfica gerada para uma única sessão ou transação e descartada em seguida, impedindo que comunicações passadas sejam decifradas se uma chave de longo prazo for exposta posteriormente.

⚠ **Armadilha CompTIA:** Watch for 'ephemeral' on the exam — it is the single word that signals PFS. If a question offers both DH and ECDHE, ECDHE is the secure, modern choice.

• Diffie-Hellman Efêmero de Curva Elíptica (ECDHE)

O método moderno de troca de chaves do TLS que usa criptografia de curva elíptica com chaves efêmeras por sessão, oferecendo Sigilo Encaminhado Perfeito com chaves menores e cálculo mais rápido que o DHE clássico.

⚠ **Armadilha CompTIA:** Exam trigger 'modern TLS key exchange with forward secrecy' = ECDHE. Distinguish from static ECDH: the trailing 'E' (Ephemeral) is what provides PFS.

• Diffie-Hellman Efêmero (DHE)

Variante sem curva elíptica do Diffie-Hellman efêmero, que gera um novo par de chaves DH a cada sessão para fornecer Sigilo Encaminhado Perfeito, porém com chaves maiores e maior custo de CPU que o ECDHE.

⚠ **Armadilha CompTIA:** Both DHE and ECDHE provide PFS — pick ECDHE when the question specifies elliptic curve or modern performance; pick DHE only when ECC is unavailable.

• Acordo de Chaves (N/A)

Categoria de protocolos criptográficos na qual AMBAS as partes contribuem com material para derivar a chave de sessão compartilhada, em contraste com o transporte de chaves, onde uma parte gera e envia a chave à outra.

⚠ **Armadilha CompTIA:** If the question asks 'what type of cryptography is Diffie-Hellman?' the answer is 'key agreement protocol', NOT 'key exchange protocol' in the strict CompTIA vocabulary — know the distinction from key transport (RSA).

• Criptografia de Curva Elíptica (ECC)

Criptografia de chave pública baseada na estrutura algébrica de curvas elípticas sobre corpos finitos, oferecendo segurança equivalente ao RSA/DH com tamanhos de chave significativamente menores (ex.: ECC de 256 bits ≈ RSA de 3072 bits).

⚠ **Armadilha CompTIA:** Exam trigger 'smaller keys with equivalent security' = ECC. Remember: ECDHE = ECC + DH + Ephemeral → modern PFS solution in TLS.

• Segredo Compartilhado (N/A)

A chave simétrica idêntica calculada independentemente por ambas as partes ao final de uma troca Diffie-Hellman, derivada do valor privado de cada lado combinado com o valor público da outra parte.

⚠ **Armadilha CompTIA:** The shared secret is the OUTPUT of DH and is then used (often with a KDF like HKDF) to derive the actual symmetric session keys for encryption — don't confuse the derived secret with the final session key.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa financeira está atualizando sua configuração de TLS. A equipe de segurança exige que, se um atacante roubar a chave privada de longo prazo do servidor web no próximo ano, as sessões TLS gravadas deste ano permaneçam confidenciais. Qual mecanismo de troca de chaves a equipe deve priorizar?

- A) Transporte de chave RSA estático
- B) Diffie-Hellman efêmero com curva elíptica (ECDHE)
- C) Diffie-Hellman estático usando uma chave fixa do servidor
- D) Apenas autenticação com chave pré-compartilhada (PSK)

QUESTÃO 2 · CENÁRIO DE EXAME

Uma startup está projetando um protocolo de mensagens. Dois clientes precisam estabelecer uma chave de sessão simétrica por uma rede não confiável sem nunca transmitir a chave de sessão e sem compartilhar um segredo previamente. Qual técnica criptográfica atende melhor a esse requisito?

- A) Troca de chaves Diffie-Hellman
- B) Criptografia RSA da chave de sessão com a chave pública do servidor
- C) Criptografia AES-256-GCM da chave de sessão
- D) Derivação de chave HMAC-SHA256

QUESTÃO 3 · CENÁRIO DE EXAME

Durante uma revisão de projeto, um engenheiro propõe usar Diffie-Hellman estático com o mesmo valor privado em todas as conexões TLS para reduzir o uso de CPU. Qual é a principal desvantagem de segurança dessa proposta?

- A) Impede que o servidor use certificados.
- B) Torna o segredo compartilhado visível publicamente na rede.
- C) Não fornece Perfect Forward Secrecy se o valor privado estático for comprometido.
- D) Exige uma chave simétrica maior do que o DH efêmero.

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa implanta um protocolo personalizado de transferência de arquivos que usa Diffie-Hellman não autenticado para acordar chaves. Um atacante na mesma rede pode modificar mensagens entre os dois endpoints. Qual é o resultado mais provável?

- A) O atacante pode realizar um ataque man-in-the-middle e estabelecer segredos compartilhados separados com cada endpoint.
- B) O atacante pode recuperar os valores privados Diffie-Hellman por força bruta em tempo real.
- C) O atacante pode forçar os endpoints a usar AES em vez de 3DES.
- D) O atacante pode descriptografar o segredo compartilhado diretamente porque ele é enviado em texto claro.

QUESTÃO 5 · CENÁRIO DE EXAME

Uma varredura de vulnerabilidades relata que um gateway VPN oferece suporte a DHE com primo de 1024 bits. Qual ação aborda melhor o risco enquanto preserva o sigilo futuro?

- A) Substituir DHE por transporte de chave RSA estático.
- B) Desabilitar todas as trocas de chaves efêmeras e usar chaves pré-compartilhadas.
- C) Trocar AES-GCM por modo CBC para criptografia de sessão.
- D) Aumentar o tamanho do primo DHE para pelo menos 2048 bits ou migrar para ECDHE com curvas aprovadas.

QUESTÃO 6 · CENÁRIO DE EXAME

Um aplicativo de banco móvel deve usar TLS com sigilo futuro, mas tem CPU e bateria limitadas. O arquiteto quer minimizar a sobrecarga criptográfica mantendo segurança forte. Qual troca de chaves é mais apropriada?

- A) ECDHE com uma curva elíptica moderna
- B) Troca de chaves RSA estática com chave de 4096 bits
- C) DHE com primo de 8192 bits
- D) Transporte de chave RSA com chaves de sessão AES-256

QUESTÃO 7 · CENÁRIO DE EXAME

Um respondedor de incidentes descobre que um atacante obteve a chave privada TLS de longo prazo de um servidor web. O servidor estava configurado com TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256. Qual afirmação descreve melhor o impacto sobre sessões TLS gravadas anteriormente?

- A) Todas as sessões anteriores podem ser descriptografadas porque a chave RSA foi usada para troca de chaves.
- B) Sessões anteriores podem ser descriptografadas apenas se AES-128 também for quebrado.
- C) Sessões anteriores que usaram chaves ECDHE efêmeras exclusivas permanecem confidenciais.
- D) Sessões anteriores são vulneráveis porque SHA256 faz hash da chave de sessão.

QUESTÃO 8 · CENÁRIO DE EXAME

Um analista de segurança vê a suíte de cifras TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 em uma captura de pacotes. Qual componente indica que a sessão pode alcançar Perfect Forward Secrecy?

- A) ECDSA
- B) AES_256_GCM
- C) SHA384
- D) ECDHE

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa quer construir uma VPN em que ambos os endpoints se autenticuem com certificados digitais e então derivem uma chave simétrica exclusiva para cada sessão. Qual projeto atende melhor a esses requisitos?

- A) Usar ECDHE para acordo de chaves e certificados para autenticação.
- B) Usar criptografia RSA estática para transporte de chave e nenhuma autenticação.
- C) Usar AES-GCM para criptografar os valores públicos Diffie-Hellman e depender de HMAC para autenticação.
- D) Usar uma única chave pré-compartilhada para todas as sessões e rotacioná-la anualmente.

QUESTÃO 10 · CENÁRIO DE EXAME

Dois sistemas concluem uma troca Diffie-Hellman pela Internet. Depois de calcular o segredo compartilhado, eles o usam para derivar chaves de sessão simétricas. Qual afirmação descreve corretamente a troca?

- A)** O segredo compartilhado é enviado pela rede criptografado com as chaves públicas dos pares.
- B)** Os valores públicos são mantidos em segredo e nunca transmitidos.
- C)** O segredo compartilhado é igual ao valor público de cada par.
- D)** Cada par combina seu próprio valor privado com o valor público do outro par para calcular o mesmo segredo compartilhado.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Diffie-Hellman efêmero com curva elíptica (ECDHE)

O ECDHE usa um par de chaves efêmero para cada sessão, então a chave de sessão não pode ser derivada da chave privada de longo prazo do servidor. RSA estático e DH estático não oferecem PFS; um projeto apenas com PSK estática também não fornece sigilo futuro por sessão.

Questão 2: Alternativa A — Troca de chaves Diffie-Hellman

O Diffie-Hellman permite que duas partes derivem o mesmo segredo compartilhado trocando apenas valores públicos; o segredo em si nunca é transmitido. O transporte de chave RSA envia um segredo criptografado, e AES e HMAC não realizam acordo de chaves.

Questão 3: Alternativa C — Não fornece Perfect Forward Secrecy se o valor privado estático for comprometido.

O DH estático reutiliza o mesmo valor privado, então o comprometimento desse valor pode permitir a descryptografia de sessões passadas gravadas. O DH não expõe o segredo compartilhado, certificados ainda são possíveis, e o tamanho da chave simétrica não é o problema principal.

Questão 4: Alternativa A — O atacante pode realizar um ataque man-in-the-middle e estabelecer segredos compartilhados separados com cada endpoint.

O DH não autenticado é vulnerável a MITM: o atacante substitui valores públicos e compartilha um segredo com cada lado. O segredo compartilhado não é enviado em texto claro, e quebrar valores privados DH adequados por força bruta não é um ataque prático em tempo real.

Questão 5: Alternativa D — Aumentar o tamanho do primo DHE para pelo menos 2048 bits ou migrar para ECDHE com curvas aprovadas.

Grupos DH fracos podem ser atacados de forma mais viável e estão associados a problemas no estilo Logjam. Migrar para DH de pelo menos 2048 bits ou ECDHE aprovado preserva o PFS. RSA estático e PSK estática não oferecem o mesmo sigilo futuro, e o modo de cifra não tem relação.

Questão 6: Alternativa A — ECDHE com uma curva elíptica moderna

O ECDHE fornece PFS com chaves muito menores e menor sobrecarga computacional do que DHE com primos grandes, o que é importante em dispositivos móveis. O transporte de chave RSA estático não oferece PFS.

Questão 7: Alternativa C — Sessões anteriores que usaram chaves ECDHE efêmeras exclusivas permanecem confidenciais.

Em ECDHE_RSA, o RSA autentica o handshake, mas a troca de chaves real usa chaves ECDHE efêmeras. O comprometimento da chave privada RSA de longo prazo não revela segredos efêmeros passados, então o PFS protege as sessões gravadas.

Questão 8: Alternativa D — ECDHE

ECDHE é a troca de chaves efêmera que fornece PFS. ECDSA é usada para autenticação/assinaturas, AES-GCM é a cifra simétrica, e SHA384 é usada no handshake/MAC/KDF.

Questão 9: Alternativa A — Usar ECDHE para acordo de chaves e certificados para autenticação.

O ECDHE fornece acordo de chaves por sessão com sigilo futuro, enquanto certificados digitais autenticam cada endpoint e ajudam a prevenir MITM. RSA estático sem autenticação, valores públicos criptografados ou uma única PSK de longa duração não atendem a todos os requisitos.

Questão 10: Alternativa D — Cada par combina seu próprio valor privado com o valor público do outro par para calcular o mesmo segredo compartilhado.

No Diffie-Hellman, valores públicos são trocados abertamente, mas cada lado usa seu próprio valor privado e o valor público do outro para calcular o mesmo segredo compartilhado. O segredo em si não é transmitido, e não é igual a um valor público.